

МІНІСТЕРСТВО ОСВІТИ І НАУКИ УКРАЇНИ
ХАРКІВСЬКИЙ НАЦІОНАЛЬНИЙ УНІВЕРСИТЕТ
РАДІОЕЛЕКТРОНІКИ

Кафедра «Програмна інженерія»

ЗВІТ
з практичної роботи №1-2
«UX/UI дизайн з AI-асистентом на основі специфікації програмного продукту»

з дисципліни «Штучний інтелект у програмній інженерії»

Виконали:
Студенти групи ПЗП-23-10
Кисельов Олександр
Паламарчук Антон
Татьков Олександр
Сергєєва Таїсія
Панковський Тимофій

Перевірила:
доцент кафедри ПІ
Шевченко О. Л.

Харків
2026

Cloud Account Management System

Хмарна система керування та зберігання облікових записів онлайн-сервісу

Специфікація вимог (SD_Spec) • розділи 0–9 • версія 0.1 (чернетка)

Примітка. Документ побудовано за структурою специфікації Mini Issue Tracker. Оскільки замовник не надав відповідей, відповіді на Open Questions, числові параметри (терміни дії токенів, ліміти спроб, довжина пароля) та обсяг MVP сформульовано як пропозиції автора і позначено «прийнято як робоче рішення». Їх необхідно погодити із замовником/викладачем.

0. Початковий запит замовника — Customer Request

Онлайн-сервісу потрібна хмарна система для керування обліковими записами користувачів та їх безпечного зберігання. Користувач самостійно реєструється, підтверджує пошту, входить у систему, переглядає й оновлює свій профіль, змінює або відновлює пароль. Адміністратор бачить облікові записи, блокує й розблоковує їх та керує ролями. Система має працювати в хмарі, безпечно зберігати дані облікових записів і бути готовою до подальшого розширення: багатофакторна автентифікація, вхід через зовнішніх провайдерів та автоматичне виявлення підозрілої активності.

1. Discovery / Problem Analysis

Bxiд: Customer Request. Bxiд: Problem Statement + Product Goals + Stakeholders + Primary Users + Known Constraints + Assumptions + Open Questions.

Problem Statement

Онлайн-сервіс не має єдиного централізованого місця для створення, автентифікації, зберігання та контролю облікових записів. Через це складно гарантувати безпеку облікових даних, швидко реагувати на компрометацію акаунтів та контролювати, хто і які права має в системі.

Product Business Goal

Забезпечити безпечну й зручну реєстрацію та автентифікацію користувачів і скоротити час реакції адміністратора на проблемні або скомпрометовані облікові записи.

Stakeholders (зацікавлені особи)

Primary

- End User (користувач сервісу)
- Administrator (адміністратор облікових записів)

Secondary

- Product Owner / замовник
- Security Officer (відповідальний за інформаційну безпеку)
- Customer Support
- DevOps / хмарний оператор

Secondary stakeholders мають інтерес до результатів або належної роботи системи, але не є основними користувачами та не беруть безпосередньої участі в основних сценаріях MVP.

Primary Users

- End User;

- Administrator.

Constraints

КС-01. Система є сервісом автентифікації та керування обліковими записами для одного онлайн-сервісу (single-tenant).

КС-02. Перший реліз має бути простим і швидким у розробці.

КС-03. Система розгортається в хмарному середовищі й доступна як web application.

КС-04. Дані облікових записів є персональними; система має відповідати вимогам захисту персональних даних (напр. GDPR / Закон України «Про захист персональних даних»).

КС-05. У першій версії не планується інтеграція із зовнішніми identity-провайдерами (Google, Microsoft, GitHub тощо).

КС-06. Багатофакторна автентифікація та AI-функціональність не є обов'язковими для першого релізу.

КС-07. Архітектура має бути придатною для подальшого додавання MFA, SSO та AI-аналізу активності.

КС-08. Для надсилання листів використовується зовнішній поштовий сервіс (конкретний провайдер — TBD).

Assumptions

A-01. Припускаємо, що кожен обліковий запис ідентифікується унікальною адресою електронної пошти.

A-02. Припускаємо, що кількість облікових записів — до кількох десятків тисяч.

A-03. Припускаємо, що одночасно працює до кількох сотень користувачів.

A-04. Припускаємо, що користувач має рівно одну роль (User або Administrator).

A-05. Припускаємо, що адреса електронної пошти користувачу доступна й лист надходить протягом хвилин.

A-06. Припускаємо, що мобільний застосунок для першої версії не потрібний (адаптивний web достатній).

A-07. Припускаємо, що AI-функції будуть лише рекомендаційними й не блокуватимуть акаунти автоматично.

A-08. Припускаємо, що даних для навчання моделі виявлення аномалій на початку буде недостатньо.

Open Questions та відповіді (прийнято як робочі рішення)

- Чи потрібна автентифікація? Так. Вхід за e-mail і паролем.
- Хто може створити обліковий запис? Будь-яка особа шляхом самореєстрації. Один початковий Administrator створюється під час розгортання системи.
- Які ролі? User, Administrator.
- Які статуси облікового запису? Pending Verification, Active, Blocked.
- Який статус отримує акаунт під час реєстрації? Pending Verification.
- Хто може блокувати/розблокувати акаунт і змінювати роль? Лише Administrator.
- Чи можна видаляти обліковий запис? Ні. У MVP акаунти лише блокуються (питання видалення за запитом власника даних — відкрите, див. R-02).
- Чи можна змінити e-mail? Ні, у MVP e-mail є незмінним ідентифікатором.
- Чи потрібна історія подій? Так, журнал подій безпеки, доступний Administrator.

- Чи потрібна MFA? Бажано, але не в першому релізі.

2. Product Vision + Initial Product Scope

Bxið: Problem Statement + Product Goals + Stakeholders + Primary Users + Constraints + Assumptions.

Buxið: Product Vision + Initial Product Scope + Initial Product Capabilities.

Product Vision: Cloud Account Management System — хмарна вебсистема, призначена для реєстрації, автентифікації, безпечного зберігання та адміністрування облікових записів користувачів онлайн-сервісу.

Initial Product Scope

- самореєстрація та підтвердження облікових записів;
- автентифікація користувачів і керування сесіями;
- самообслуговування: профіль, зміна та відновлення пароля;
- адміністрування облікових записів: перегляд, блокування, ролі;
- журналювання подій безпеки;
- посилений захист входу: багатофакторна автентифікація;
- інтелектуальна підтримка: виявлення підозрілої активності.

Out of Scope на поточному етапі:

Керування бізнес-даними самого онлайн-сервісу; білінг і підписки; Single Sign-On та social login; multi-tenant / організації; ролі з гнучкими правами (RBAC-конструктор); мобільний застосунок; підтримка клієнтів (helpdesk); видалення акаунтів; тощо.

Initial Product Capabilities

ID	Product Capability	Що означає на цьому рівні
C-01	Account Registration & Verification	Створювати облікові записи та підтверджувати належність e-mail
C-02	Authentication & Session Management	Перевіряти особу користувача та керувати його сесіями
C-03	Self-service Account Management	Дозволяти користувачу керувати власним профілем і паролем
C-04	Account Administration	Дозволяти адміністратору переглядати акаунти, блокувати їх і призначати ролі
C-05	Security Audit	Фіксувати та показувати події безпеки
C-06	Advanced Authentication	Посилювати вхід додатковими факторами (MFA)
C-07	AI-assisted Threat Detection	Автоматично виявляти підозрілу активність і рекомендувати дії

3. Stakeholder Needs & Stakeholder Requirements

Bxið: Problem Statement + Stakeholders + Primary Users + Product Vision + Initial Product Scope + Initial Product Capabilities + Constraints + Assumptions + Open Questions. Buxið: Stakeholder Needs + Business Rules + Stakeholder Constraints + Refined Product Scope + Remaining Open Questions.

SR-01 — Register account. Користувач повинен мати можливість створити власний обліковий запис.

SR-02 — Authenticate. Користувач повинен мати можливість увійти в систему та вийти з неї.

SR-03 — Verify e-mail. Система повинна підтверджувати, що адреса електронної пошти належить користувачу.

SR-04 — Manage profile. Користувач повинен мати можливість переглядати та оновлювати свій профіль.

SR-05 — Change password. Користувач повинен мати можливість змінити свій пароль.

SR-06 — Recover password. Користувач повинен мати можливість відновити доступ у разі втрати пароля.

SR-07 — View accounts. Адміністратор повинен мати можливість переглядати облікові записи й знаходити потрібний.

SR-08 — Block accounts. Адміністратор повинен мати можливість заблокувати та розблокувати обліковий запис.

SR-09 — Manage roles. Адміністратор повинен мати можливість призначати роль облікового запису. У разі конфліктів вирішує Administrator.

SR-10 — Security event log. Адміністратор повинен мати можливість переглядати журнал подій безпеки.

SR-11 — Protect stored credentials. Облікові дані повинні зберігатися безпечно й не бути доступними в явному вигляді нікому, включно з адміністраторами.

SR-12 — Multi-factor authentication. Користувач повинен мати можливість ввімкнути додатковий фактор входу.

SR-13 — External sign-in. Користувач повинен мати можливість входити через зовнішнього identity-провайдера.

SR-14 — Suspicious activity detection. Система повинна допомагати виявляти підозрілу активність облікових записів.

Business Rules

BR-01 — Roles

Система має дві ролі: User та Administrator. Під час розгортання створюється один початковий Administrator. Решта акаунтів — User.

BR-02 — Registration

Будь-яка особа може створити обліковий запис, вказавши унікальні e-mail, display name і пароль.

BR-03 — Initial account status

Під час реєстрації система автоматично встановлює: status = Pending Verification, role = User.

BR-04 — Allowed status values

Status може мати одне з таких значень: Pending Verification, Active, Blocked.

BR-04.1 — Status transitions

Дозволені переходи: Pending Verification → Active (підтвердження e-mail); Active → Blocked; Blocked → Active (лише Administrator). Інші переходи не дозволені.

BR-05 — Login eligibility

Увійти може лише акаунт зі status = Active.

BR-06 — Credential storage

Пароль ніколи не зберігається й не відображається в явному вигляді; зберігається лише результат стійкого хешування з унікальною «сіллю».

BR-07 — Password policy

Пароль: не менше 10 символів, містить щонайменше одну літеру та одну цифру. Новий пароль не збігається з поточним.

BR-08 — Login throttling

Після 5 невдалих спроб входу поспіль протягом 15 хвилин вхід для цього акаунта тимчасово блокується на 15 хвилин. Це не змінює status акаунта.

BR-09 — One-time tokens

Токен підтвердження e-mail дійсний 24 години, токен відновлення пароля — 30 хвилин. Кожен токен одноразовий; новий токен того ж типу скасовує попередній.

BR-10 — Non-disclosure

Відповідь на запит відновлення пароля однакова незалежно від того, чи існує e-mail у системі. Повідомлення про помилку входу не вказує, що саме невірне — e-mail чи пароль.

BR-11 — Access to accounts

Користувач бачить і змінює лише власний профіль. Перегляд усіх акаунтів, блокування та зміна ролей доступні лише Administrator.

BR-12 — Administrator safeguards

Administrator не може заблокувати себе або змінити власну роль. У системі завжди має залишатися щонайменше один Active Administrator.

BR-13 — Immutable e-mail

E-mail не змінюється після реєстрації. Профіль містить редаговані поля: Display name, Phone (необов'язково).

BR-14 — Account deletion

Облікові записи не видаляються із системи.

BR-15 — Session

Сесія завершується після виходу, зміни/відновлення пароля, блокування акаунта або 30 хвилин неактивності.

BR-16 — Security events

Система фіксує події: реєстрація, підтвердження e-mail, успішний і невдалий вхід, зміна пароля, відновлення пароля, блокування/розблокування, зміна ролі. Журнал не містить паролів, хешів і токенів.

BR-17 — AI recommendations

AI-функціональність, якщо буде реалізована, має рекомендаційний характер: система може позначати підозрілу активність, але не блокує акаунти автоматично без дії Administrator.

4. Prioritization of Needs + Candidate MVP

BxiD: Product Goals + Refined Product Scope + Stakeholder Requirements + Business Value + Dependencies + Risks + Constraints + Rough technical estimates. BuxiD: Prioritized Stakeholder Requirements + Candidate MVP + Deferred Requirements + Future Requirements + Prioritization Rationale.

Prioritized Stakeholder Requirements

Requirement	Priority	Rough Effort
SR-01 Register account	Must	Small
SR-02 Authenticate	Must	Medium
SR-03 Verify e-mail	Must	Medium
SR-04 Manage profile	Must	Small
SR-05 Change password	Must	Small
SR-06 Recover password	Must	Medium

Requirement	Priority	Rough Effort
SR-07 View accounts	Must	Small
SR-08 Block accounts	Must	Small
SR-09 Manage roles	Should	Small
SR-10 Security event log	Should	Medium
SR-11 Protect stored credentials	Must	Medium
SR-12 Multi-factor authentication	Should	Large
SR-13 External sign-in	Won't for now	Large / uncertain
SR-14 Suspicious activity detection	Won't for now	Large / uncertain

Candidate MVP

Must + Should (ті з Should, що плануємо дозволити собі): з SR-01 по SR-12.

Future / Deferred Requirements

SR-13 та SR-14.

Prioritization Rationale

Must — мінімальний набір, без якого користувач не може створити акаунт і безпечно увійти, а адміністратор не може контролювати акаунти. SR-09 і SR-10 підвищують керованість і безпеку, але акаунтами можна керувати й без них у вкрай спрощеному режимі. SR-12 має високу цінність, проте суттєво ускладнює перший реліз. SR-13 і SR-14 залежать від зовнішніх провайдерів і накопичених даних.

5. Detailed Functional Requirements Specification / User Stories + Acceptance Criteria

Bxiд: Prioritized Stakeholder Requirements + Candidate MVP + Known Constraints + Relevant Assumptions + Open Questions + Primary Users. Buxiд: Detailed FR або User Stories + Acceptance Criteria.

User Stories

Epic 1 — Account Lifecycle

Як користувач сервісу, я хочу створити обліковий запис, підтвердити його та безпечно входити в систему.

Story US-01 — Register Account

As an end user I want to create an account with e-mail, display name and password So that I can access the online service.

Acceptance Criteria

AC-01.1 Користувач може ввести: Email, Display name, Password, Confirm password.

AC-01.2 Усі поля є обов'язковими.

AC-01.3 Email повинен мати коректний формат і бути унікальним у системі; інакше акаунт не створюється й показується повідомлення про помилку.

AC-01.4 Password повинен відповідати політиці BR-07; Confirm password має збігатися з Password.

AC-01.5 Після створення акаунт отримує: ID, status = Pending Verification, role = User, created_at.

АС-01.6 Після створення на вказаний e-mail надсилається лист із посиланням підтвердження.

АС-01.7 Акаунт зі статусом Pending Verification не може увійти в систему.

Альтернативне подання АС у форматі Gherkin (Given-When-Then)

Сценарій для АС-01.1, АС-01.5

```
Given the user is on the "Register" page
When the user enters e-mail "anna@example.com"
  And display name "Anna"
  And a valid password twice
  And clicks "Register"
Then a new account is created
  And its status is "Pending Verification"
  And its role is "User"
  And a verification e-mail is sent to "anna@example.com"
```

Сценарій для АС-01.3

```
Given an account with e-mail "anna@example.com" already exists
When a user tries to register with "anna@example.com"
Then the account is not created
  And the system displays "Email is already registered"
```

Сценарій для АС-01.4

```
Given the user is on the "Register" page
When the user enters the password "12345"
  And clicks "Register"
Then the account is not created
  And the system displays the password requirements
```

Story US-02 — Verify E-mail

As a newly registered user, I want to confirm my e-mail address, so that my account becomes active.

Acceptance Criteria

АС-02.1 Лист містить унікальне посилання, дійсне 24 години.

АС-02.2 Перехід за дійсним посиланням змінює status на Active та показує повідомлення про успіх.

АС-02.3 Недійсне або прострочене посилання не активує акаунт; користувач бачить повідомлення й можливість запросити нове посилання.

АС-02.4 Використане посилання не можна застосувати повторно.

АС-02.5 Користувач із Pending Verification може запросити повторне надсилання листа; попереднє посилання перестає діяти.

Story US-03 — Log In and Log Out

As a user, I want to log in with my e-mail and password and log out, so that only I have access to my account.

Acceptance Criteria

АС-03.1 Користувач вводить Email і Password.

АС-03.2 Для акаунта зі status = Active та вірними даними створюється сесія; користувач потрапляє на сторінку свого профілю.

АС-03.3 За невірних даних вхід не виконується; повідомлення не вказує, що саме невірне («Invalid email or password»).

АС-03.4 Для Pending Verification система повідомляє, що e-mail потрібно підтвердити.

AC-03.5 Для Blocked після введення вірних даних система повідомляє, що акаунт заблоковано.

AC-03.6 Після 5 невдалих спроб поспіль вхід тимчасово блокується на 15 хвилин відповідно до BR-08.

AC-03.7 Вихід завершує сесію; після цього захищені сторінки недоступні без повторного входу.

AC-03.8 Сесія завершується після 30 хвилин неактивності.

Epic 2 — Self-service

Story US-04 — View and Edit Profile

As a user, I want to view and edit my profile, so that my personal data is up to date.

Acceptance Criteria

AC-04.1 Профіль відображає: Email, Display name, Phone, Role, Status, Created at.

AC-04.2 Користувач може змінити Display name (обов'язкове, 2–50 символів) та Phone (необов'язкове).

AC-04.3 Email не можна змінити.

AC-04.4 Після збереження нові значення відображаються при наступному перегляді.

AC-04.5 Користувач не може переглядати чи змінювати профіль іншого користувача.

AC-04.6 Якщо збереження не вдалося, зміни не застосовуються, показується помилка.

Story US-05 — Change Password

As a logged-in user, I want to change my password, so that I can keep my account secure.

Acceptance Criteria

AC-05.1 Користувач вводить Current password, New password, Confirm new password.

AC-05.2 Якщо Current password невірний, пароль не змінюється.

AC-05.3 New password відповідає політиці BR-07 і відрізняється від поточного.

AC-05.4 Якщо Confirm new password не збігається, пароль не змінюється й показується помилка.

AC-05.5 Після успіху діє лише новий пароль; усі інші сесії користувача завершуються; на e-mail надсилається повідомлення про зміну.

Story US-06 — Reset Forgotten Password

As a user who forgot the password, I want to reset it via e-mail, so that I can regain access.

Acceptance Criteria

AC-06.1 Користувач може ввести Email на сторінці відновлення.

AC-06.2 Система показує однакове повідомлення незалежно від того, чи існує такий e-mail (BR-10).

AC-06.3 Для акаунта зі status = Active надсилається посилання, дійсне 30 хвилин. Для Pending Verification та Blocked посилання не надсилається.

AC-06.4 За дійсним посиланням користувач задає новий пароль, що відповідає BR-07.

AC-06.5 Використане, прострочене або скасоване посилання відхиляється з повідомленням.

AC-06.6 Після успішного відновлення всі сесії завершуються, лічильник невдалих входів скидається.

Epic 3 — Administration

Story US-07 — View Accounts (Administrator)

As an administrator, I want to see and find user accounts, so that I can control who has access.

Acceptance Criteria

- AC-07.1** Список облікових записів доступний лише Administrator.
- AC-07.2** Для кожного акаунта у списку відображаються щонайменше: ID, Email, Display name, Role, Status, Created at.
- AC-07.3** Список можна відфільтрувати за Status.
- AC-07.4** Список можна відфільтрувати пошуком за частиною Email.
- AC-07.5** Administrator може відкрити сторінку деталей акаунта.
- AC-07.6** Якщо акаунтів немає або нічого не знайдено, система показує відповідне повідомлення.
- AC-07.7** Паролі й хеші паролів ніколи не відображаються.
- AC-07.8** User, який не є Administrator, отримує відмову в доступі.

Story US-08 — Block and Unblock Account

As an administrator, I want to block and unblock accounts, so that I can stop misuse.

Acceptance Criteria

- AC-08.1** Блокувати та розблоковувати акаунти може лише Administrator.
- AC-08.2** Active → Blocked та Blocked → Active; інші зміни статусу через цю дію не дозволені (BR-04.1).
- AC-08.3** Після блокування всі активні сесії акаунта завершуються, вхід неможливий.
- AC-08.4** Administrator не може заблокувати власний акаунт.
- AC-08.5** Після розблокування користувач може входити зі своїм поточним паролем.
- AC-08.6** Блокування та розблокування записуються в журнал подій безпеки.

Story US-09 — Assign Role

As an administrator, I want to assign a role to an account, so that users have appropriate permissions.

Acceptance Criteria

- AC-09.1** Змінювати role може лише Administrator.
- AC-09.2** Допустимі значення: User, Administrator.
- AC-09.3** Administrator не може змінити власну роль.
- AC-09.4** У системі завжди залишається щонайменше один Active Administrator.
- AC-09.5** Нова роль діє не пізніше наступного запиту користувача.
- AC-09.6** Зміна ролі записується в журнал подій безпеки.

Story US-10 — View Security Event Log

As an administrator, I want to view security events, so that I can investigate incidents.

Acceptance Criteria

- AC-10.1** Журнал доступний лише Administrator.
- AC-10.2** Кожен запис містить: час, тип події, ініціатора, цільовий акаунт, результат (success/failure).
- AC-10.3** Журнал охоплює події, перелічені в BR-16.
- AC-10.4** Записи відображаються від найновіших до найстаріших.

АС-10.5 Журнал не містить паролів, хешів і токенів.

АС-10.6 Журнал можна відфільтрувати за типом події.

АС-10.7 Через інтерфейс запис журналу не можна змінити або видалити.

Story US-11 — Enable Multi-Factor Authentication

As a user, I want to enable a second authentication factor, so that my account is protected even if my password leaks.

Acceptance Criteria: не деталізуються на цьому етапі, оскільки історія відкладена (див. розділ 7). Орієнтовні вимоги: вибір методу (TOTP-застосунок), резервні коди, процедура відновлення доступу.

Dependencies

- US-03 (Log In) → US-01 (Register), US-02 (Verify E-mail)
- US-06 (Reset Password) → US-02 (акаунт має бути Active)
- US-08 (Block) → US-07 (View Accounts)
- US-09 (Assign Role) → US-07 (View Accounts)
- US-10 (Security Log) → US-01...US-09 (джерела подій)

6. Quality Attributes + Security Requirements

Bxið: Functional requirements + Business constraints. Buxið: Non-functional / Quality / Security Requirements.

ID	Вимога	Категорія
NFR-01	Час відповіді операцій входу та перегляду профілю < 1 с для 95% запитів при навантаженні до 300 одночасних користувачів	Performance
NFR-02	Автентифікація обов'язкова для всіх сторінок, крім реєстрації, входу, підтвердження та відновлення	Security
NFR-03	Лише HTTPS (TLS 1.2+); HTTP перенаправляється або відхиляється	Security
NFR-04	Паролі зберігаються лише як адаптивні хеші з унікальною сіллю (напр. Argon2id / bcrypt)	Security
NFR-05	Захист від перебору: обмеження частоти запитів (rate limiting) до входу, реєстрації та відновлення	Security
NFR-06	Шифрування персональних даних у сховищі (encryption at rest)	Security
NFR-07	Захист від типових веб-атак: XSS, CSRF, SQL injection	Security
NFR-08	Резервне копіювання всіх даних облікових записів і журналу; перевірене відновлення	Reliability
NFR-09	Доступність сервісу не нижче 99,5% на місяць	Availability
NFR-10	Збереження та обробка персональних даних відповідно до застосовного законодавства; мінімізація даних	Compliance
NFR-11	Журнал подій зберігається не менше 12 місяців (робоче значення)	Auditability

ID	Вимога	Категорія
NFR-12	Система має розгортатися в хмарі з підтримкою горизонтального масштабування без зміни логіки застосунку	Scalability
NFR-13	Інтерфейс адаптивний і працює в актуальних версіях Chrome, Firefox, Edge, Safari	Usability

7. Feasibility, Estimation & Risk Assessment

BxiD: Candidate MVP + Detailed FR + NFR + Business Rules + Constraints + Relevant Assumptions + Known dependencies. BuxiD: Rough Effort Assessment + Key Risks + Technical Feasibility Assessment + Recommended Scope Adjustments.

Попередня оцінка показала, що вимоги US-01–US-10 можуть бути реалізовані в межах першого релізу на стандартному хмарному стеку (керована БД, поштовий сервіс, менеджер секретів) без складної додаткової інфраструктури.

US-11 — Enable Multi-Factor Authentication має значно вищу складність, оскільки потребує:

- додаткового сховища секретів фактора та резервних кодів;
- процедури відновлення доступу при втраті фактора;
- узгодження з політикою сесій, скиданням пароля та журналом подій;
- розширеного тестування безпеки.

Risk Register

ID	Ризик	Ймовірність / вплив	Реакція
R-01	Спосіб реалізації автентифікації та сесій (server session чи токени) потребує уточнення	Середня / Висока	Technical spike
R-02	Вимоги законодавства щодо персональних даних, у т.ч. право на видалення, суперечать BR-14 (акаунти не видаляються)	Середня / Висока	Юридична консультація; можлива зміна BR-14 (анонімізація)
R-03	Залежність від зовнішнього поштового сервісу: затримки або недоставка листів блокують реєстрацію й відновлення	Середня / Середня	Вибір провайдера; повторне надсилання; моніторинг
R-04	Реалізація MFA суттєво збільшує складність першого релізу	Висока / Середня	Відкласти US-11
R-05	Для майбутнього AI-виявлення аномалій може бути недостатньо даних	Висока / Низька (для MVP)	Накопичувати журнал подій; правила замість ML на старті
R-06	Компрометація бази даних облікових записів	Низька / Критична	NFR-04, NFR-06, менеджер секретів, принцип найменших привілеїв

Required Technical Spikes

- SPIKE-01: сесії vs токени; зберігання та відкликання сесій (R-01).
- SPIKE-02: вибір алгоритму хешування та параметрів (NFR-04).
- SPIKE-03: вибір поштового провайдера і перевірка доставлюваності (R-03).

Technical Feasibility Assessment

Реалізація US-01–US-10 оцінюється як технічно здійсненна для web application невеликого розміру. Використання перевірених бібліотек автентифікації та керованих хмарних сервісів знижує ризик.

Recommended Scope Adjustment

Перенести US-11 — Enable Multi-Factor Authentication за межі першого релізу.

8. MVP / Release Scope

Release MVP = US-01..US-10

Deferred: US-11

Future: SR-13, SR-14

Updated NFRs

ID	Вимога
NFR-01	Response time < 1 s (95%)
NFR-02	Authentication required
NFR-03	HTTPS only
NFR-04	Passwords stored only as salted adaptive hashes
NFR-05	Rate limiting on login, registration and recovery
NFR-06	Encryption at rest for personal data
NFR-07	Protection against XSS, CSRF, SQL injection
NFR-08	Backup of all account data and security log
NFR-09	Availability ≥ 99.5% per month
NFR-10	Compliance with personal data regulations

NFR-11–NFR-13 залишаються чинними без змін.

9. UX/UI & Interaction Design

Вхід: погоджений Release Scope, US/AC, UI-релевантні BR/NFR та Decision Log. Вихід: Screen Map + Screen Contracts + Wireframes + Prototype + Traceability + Review/Defect/Change Log.

Нижче наведено початкову (пропоновану) структуру екранів, яку слід уточнити й погодити під час виконання робіт із розділу 9.

Initial Screen Inventory (PROPOSED)

ID	Екран	Актори	Джерела
S-01	Register	Гість	US-01
S-02	Login	Гість	US-03, AC-03.3–AC-03.6
S-03	Verify E-mail result	Гість	US-02
S-04	Forgot / Reset Password	Гість	US-06

ID	Екран	Актори	Джерела
S-05	My Profile (+ Change Password)	User, Administrator	US-04, US-05
S-06	Accounts List	Administrator	US-07
S-07	Account Details (block/unblock, role)	Administrator	US-07, US-08, US-09
S-08	Security Event Log	Administrator	US-10

Proposed UX Decisions (потребують погодження)

ID	Рішення
D-01	Desktop-first, адаптивний low-fidelity макет у відтинках сірого.
D-02	Дії адміністратора (Block, Role) розміщені на сторінці S-07, окремі сторінки для них не створюються.
D-03	Недоступні дії показувати як disabled (напр. Block для власного акаунта Administrator).
D-04	Зміна status/role — вибір значення + підтвердження в діалозі.
D-05	Макет і прототип використовують фіктивні дані; реальна автентифікація, надсилання листів і збереження не симулюються.

Не проєктувати в MVP

Multi-factor authentication, social login, видалення акаунта, зміна e-mail, RBAC-конструктор, AI-дашборд підозрілої активності.

Посилання на figma: [Cloud Account Management System – Figma](#)